GUÍA DE ENSAYO · GRUPO 1

Exposición técnica: 12 minutos + 3 de preguntas

Cómo funciona · Con qué funciona · Qué mostrar

La exposición se apoya en una ejecución, el código y el diagrama. Usa las frases como ideas, no como texto para memorizar. En cada bloque: muestra algo, explica el mecanismo y enlázalo con el resultado. Si el profesor interrumpe, responde con el archivo o dato correspondiente y retoma el recorrido.

Preparación antes de proyectar

• Dejar abierta la aplicación local y una ejecución guardada de respaldo. Verificar el puerto configurado.

• Abrir assets/arquitectura.png o assets/arquitectura.pdf a pantalla completa.

• Editor: agent.py, skills/gestion_riesgos.md, rag_loader.py, rag_retriever.py, risk.py, gestitel.py, publication.py.

• Terminal en la raíz. No proyectar .env, credenciales ni sesiones de inicio.

• Verificar que ACT-HW-001 siga siendo el caso ficticio EC2-DEMO antes de usarlo.

• El respaldo evidencia_ejecucion.json es una ejecución histórica previa al aislamiento normativo actual: sirve para explicar la traza y el cálculo; no prueba el RAG actual. Mostrar su fecha y esa limitación.

0:00–0:45 | Entrada y arranque

Mostrar: activo de demostración y objetivo en la aplicación. Iniciar una sola evaluación.

Idea para decir: «Voy a seguir una evaluación completa. El objetivo delimita el caso; los datos los traemos de GESTITEL. Mientras consulta, les muestro dónde se decide cada acción».

Señalar: código del activo, proceso y matriz; el caso es simulado y no contiene PII real. No leer el objetivo completo ni explicar durante un minuto para qué sirve el producto.

0:45–2:15 | Arquitectura y tecnologías

Mostrar: diagrama gráfico. Recorrer 01 → 02 → 03 → 04 y después las tres salidas de herramientas.

Idea para decir: «La interfaz manda un POST a Flask. RunStore devuelve un ID y ejecuta el trabajo en un hilo; la interfaz consulta su estado. RiskAgent conversa con el modelo por Groq. El modelo selecciona una herramienta, pero la ejecución y validación ocurren aquí, en Python».

Con qué funciona: HTML/CSS/JavaScript; Flask; ThreadPoolExecutor; Pydantic; SDK Groq; respaldo Gemini por interfaz compatible con OpenAI; urllib para GESTITEL; pypdf y TF-IDF/BM25; SQLite; ReportLab para informes. El modelo principal configurado es openai/gpt-oss-120b. Gemini es respaldo configurable, no un segundo agente ni una consulta paralela.

Cerrar el bloque: indicar dónde están ISO, datos operativos e historial. La línea discontinua representa publicación posterior con intervención humana.

2:15–3:30 | Skills: listar, abrir y comprobar la carga

Mostrar en terminal: Get-ChildItem src/priv_audit/skills (PowerShell) o ls src/priv_audit/skills. Después ejecutar python scripts/mostrar_skills.py: lista las skills, carga el archivo real y muestra el cambio de herramientas disponibles, sin llamar a IA ni a GESTITEL. --completa imprime toda la skill.

Skill en el repositorio	Estado en el agente actual	Qué mostrar
gestion_riesgos	Activa; la única permitida por LoadSkill	Abrir el archivo y señalar hechos/supuestos, privacidad, referencias y cierre
auditoria_sql	Histórica; no habilitada	Nombre en la carpeta; no presentarla como ejecutada
consulta_pims	Histórica; no habilitada	Nombre en la carpeta; no presentarla como ejecutada
control_evidencia	Histórica; no habilitada	Nombre en la carpeta; no presentarla como ejecutada

Abrir: agent.py: LoadSkill, cargar_skill, available_tools().

Idea para decir: «La skill contiene el procedimiento, no es otro modelo. Al inicio solo ofrecemos cargar_skill y el esquema solo admite gestion_riesgos. Python lee el archivo y devuelve las instrucciones al modelo como resultado de herramienta. Aquí en la actividad se puede comprobar que se cargó».

Distinguir skill (instrucciones), herramienta (función ejecutable) y modelo (elige la siguiente acción). Las skills de desarrollo usadas para preparar materiales no forman parte del agente del proyecto.

3:30–5:00 | Ciclo del agente y herramientas

Abrir: agent.py: TOOL_SPECS, run(), available_tools() y execute().

Listar las seis herramientas y señalar su implementación:

Herramienta	Ejecución y resultado
cargar_skill	Lee gestion_riesgos.md; entrega el procedimiento
preparar_contexto_riesgos	Consulta activos, procesos y matriz; adjunta extractos ISO iniciales
consultar_contexto_riesgos	Consulta uno de siete módulos permitidos de GESTITEL
buscar_documentos	Recupera fragmentos únicamente del PDF OCR ISO 27701:2025
calcular_riesgo	Python valida P/I y calcula usando la matriz recuperada
finalizar_riesgos	Comprueba referencias, activo y cálculo; entrega propuesta o evidencia insuficiente

Idea para decir: «Esta llamada trae tool_calls. Validamos los argumentos con Pydantic, ejecutamos la función y devolvemos un mensaje tool. Con ese resultado el modelo decide el siguiente paso. Las herramientas cambian según la fase: sin matriz no hay cálculo y después de calcular solo se ofrece finalizar».

Señalar límites: 16 decisiones de modelo, 300 segundos y hasta seis consultas operativas. La traza muestra acciones y resultados; no es el razonamiento interno del modelo.

5:00–6:30 | RAG y base ISO exclusiva

Abrir: rag_loader.py: cargar_pdf(), chunk_texto(), RISK_NORMATIVE_SOURCE. Después agent.py: filtro de buscar_documentos; y rag_retriever.py: Retriever.

Idea para decir: «El PDF aportado ya tiene OCR. pypdf extrae por página; dividimos el texto en fragmentos de 800 caracteres con 150 de solape. Cada uno conserva fuente, página e ID. La búsqueda usa TF-IDF con scikit-learn, o BM25 si no está instalado. No usamos embeddings ni una base vectorial externa».

Mostrar python scripts/verificar_iso_27701.py: hashes, edición, cuerpo y anexos. Son 72 páginas PDF que incluyen 64 de cuerpo; los anexos A y B son normativos. El agente solo puede recuperar ese PDF como norma. Las otras fuentes del repositorio quedan fuera de su búsqueda.

Comprobación que mostrar: python -m unittest discover -s tests -p test_risk_normative_scope.py -v. Prueba aislamiento con datos simulados; no es una ejecución en GESTITEL. Si el resultado actual tiene cita ISO, abrir el fragmento y su página. No atribuir al respaldo histórico una cita que no tiene.

6:30–8:15 | Integración y cálculo reproducible

Abrir: gestitel.py: GestitelClient.read(); risk.py: Methodology.coverage(), calculate().

Idea para decir: «La lectura usa rutas permitidas y selecciona campos. Devuelve registros con ID, fecha y procedencia. La matriz activa define escala y bandas. El modelo propone P e I y los justifica; Python multiplica, clasifica y genera calculo_id. ISO no prescribe esta fórmula P por I».

Mostrar una entrada y la salida del cálculo en la traza. Si usas P=2 e I=4 como ejemplo didáctico, el puntaje es 8; el nivel depende de las bandas recuperadas, no de una categoría universal. El inventario CID no determina por sí solo el impacto del escenario.

Señalar validaciones: rangos sin huecos ni solapes, escala compatible, activo realmente recuperado, cita del mismo activo y calculo_id existente. Sin información suficiente puede finalizar sin puntuación.

8:15–10:15 | Resultado y evidencia

Mostrar: resultado de la ejecución o abrir el respaldo diciendo expresamente que es guardado. Seguir un solo riesgo: activo → amenaza → vulnerabilidad → consecuencia → evaluación → tratamiento.

Idea para decir: «Aquí compruebo tres cosas: de qué registro sale el escenario, cómo justificó la valoración y qué evidencia pide para verificar la medida. Una copia declarada no demuestra que la restauración funcione. La propuesta pide esa prueba; no afirma haberla ejecutado».

Señalar impacto_personas, rol_tratamiento, datos_personales, supuestos e información faltante. En EC2-DEMO no hay PII real: las consecuencias de privacidad son hipotéticas. Mostrar referencia operativa y, si existe en esa ejecución, la cita ISO con página. El control del catálogo GESTITEL puede conservar un código de otra norma: es contexto operativo, no la base normativa. Para copias, la referencia propia de ISO 27701:2025 es A.3.24/B.3.24 y debe recuperarse.

Abrir Historial: SQLite conserva resultado, fuentes y traza. Mostrar exportación sin recorrer todo el informe.

10:15–11:15 | Publicación separada y revisión

Abrir: publication.py: preview() y confirm(); mostrar la vista previa si está disponible.

Idea para decir: «El agente termina en una propuesta. Guardarla en GESTITEL es otro flujo: parte del resultado persistido, vuelve a consultar el contexto y exige confirmación explícita. Después de escribir, verifica por lectura. Esa aprobación no acepta riesgo residual ni demuestra implementación».

No hacer una escritura remota solo para completar el guion. Si el grupo ya decidió publicar un caso autorizado, hacerlo dentro de este minuto; si no, mostrar preview y la validación approved is not True. No dedicar tres minutos a crear y actualizar registros.

11:15–12:00 | Comprobación final

Volver a la traza y señalar una carga de skill, una consulta, un cálculo y la finalización.

Idea para decir: «El recorrido que vimos está en estos archivos y en esta traza. El modelo decide qué herramienta pedir; Python comprueba los datos, calcula y valida la entrega. Lo que no está respaldado queda como supuesto o información faltante».

Dejar el diagrama abierto para las preguntas. Terminar el recorrido a los 12 minutos.

12:00–15:00 | Preguntas

• ¿Por qué agente? Elige herramientas, recibe sus resultados y adapta la siguiente acción.

• ¿Cuántas skills están activas? Una: gestion_riesgos. Las otras tres son históricas.

• ¿Qué modelo? Groq con openai/gpt-oss-120b; Gemini es respaldo configurable.

• ¿Cómo entra la ISO? OCR existente → extracción por página → fragmentos → recuperación filtrada → citas.

• ¿Usan embeddings? No; TF-IDF o BM25 según dependencias.

• ¿Quién calcula? Python; P/I son estimaciones justificadas por el modelo bajo una matriz recuperada.

• ¿Dónde se guarda? SQLite local; escritura remota solo mediante el flujo de aprobación.

• ¿Qué norma? Solo ISO/IEC 27701:2025. La matriz de GESTITEL es un criterio organizativo.

• ¿Se certifica cumplimiento? No; la evidencia y las propuestas requieren revisión humana.

Ensayo y contingencia

Ensayar una vez con cronómetro y pantalla. No memorizar párrafos: practicar el recorrido y las transiciones. Si a los 8:15 no terminó la tarea, usar el respaldo identificado como histórico; no duplicar ejecuciones. Si falta tiempo, omitir publicación y exportación; conservar skill, ciclo, ISO, cálculo y evidencia. A los 12:00 pasar a preguntas; a los 15:00 cerrar. No prometer una latencia fija del proveedor.